Лабораторна робота № 3

Тема: «Дослідження криптографічних протоколів та механізмів захисту платіжних систем».

Індивідуальний варіант: спосіб платежу — Apple Pay; історичний протокол — PayWord.

Виконали: Остаповець Олеся Віталіївна та Булигін Олексій Михайлович, група ФІ-52мн.

Мета роботи та використані джерела

Мета роботи — дослідити принципи побудови сучасних електронних платіжних систем, криптографічні механізми захисту платіжних операцій та основні загрози, що виникають під час здійснення електронних платежів.

Робота має аналітичний характер. Використано стандарти PCI SSC та EMVCo, постанову Правління НБУ № 58, документацію Apple з безпеки платформ і опис PayWord авторів протоколу. Перелік джерел наведено в кінці звіту. Матеріали опрацьовано станом на 30.10.2026.

1. Дослідження механізмів захисту електронних платежів

1.1. Учасники карткового платежу в Інтернеті

Таблиця 1 — Учасники карткового платежу та їхні функції

Учасник	Функції
Покупець (держатель картки)	Ініціює оплату, надає реквізити картки або токен, проходить автентифікацію в емітента
Продавець (merchant)	Формує замовлення та суму, передає оплату платіжному провайдеру, отримує результат; не повинен зберігати повні дані картки
Платіжний провайдер (PSP)	Надає платіжну сторінку або API, приймає реквізити, токенізує їх, запускає 3-D Secure, передає запит еквайру
Еквайр	Банк, що обслуговує продавця: надсилає запит авторизації в платіжну систему, зараховує кошти продавцю після розрахунків

Учасник	Функції
Платіжна система	Visa, Mastercard, ПРОСТІР: маршрутизує повідомлення між еквайром і емітентом за PAN, встановлює правила, проводить клірінг; обслуговує Directory Server 3-D Secure
Банк-емітент	Випустив картку: автентифікує держателя (ACS), перевіряє кошти, ліміти й ризики, схвалює або відхиляє операцію

1.2. Автентифікація користувача і авторизація операції

Автентифікація відповідає на питання «хто платить»: емітент перевіряє, що операцію ініціює законний держатель (пароль, OTP, біометрія в банківському застосунку).

Авторизація відповідає на питання «чи дозволити цю операцію»: емітент ухвалює рішення щодо конкретної суми й отримувача з урахуванням залишку, лімітів, статусу картки та оцінки шахрайства. Успішна автентифікація — лише один із входів авторизації: операцію можна відхилити навіть після неї, наприклад через нестачу коштів.

1.3. Роль TLS

TLS захищає кожен мережевий сегмент: браузер ↔ сторінка оплати, продавець ↔ PSP, PSP ↔ еквайр. Він забезпечує конфіденційність реквізитів, цілісність запитів і автентифікацію сервера [9]. Тим самим TLS протидіє перехопленню трафіку, зміні суми або отримувача на шляху та MITM у недовірених мережах.

TLS не захищає дані після прибуття на сервер. Він не допомагає проти зламу бази продавця, шкідливого JavaScript на сторінці оплати (веб-скімінг), фішингового сайту з чинним сертифікатом і використання викрадених реквізитів.

1.4. Токенізація платіжних реквізитів

Токенізація замінює номер картки (PAN) сурогатним значенням, з якого PAN неможливо відновити без доступу до сховища постачальника токенів. Розрізняють токени PSP для повторних платежів і мережеві токени EMV, які випускає платіжна система [3]. Мережевий токен обмежений доменом використання: конкретним продавцем, пристроєм або каналом, і використовується разом з одноразовою криптограмою.

Переваги зберігання токена замість PAN:

- викрадений токен непридатний поза своїм доменом і без криптограми;
- продавець не зберігає PAN, тому зменшується обсяг вимог PCI DSS для його систем;
- скомпрометований токен можна відкликати без перевипуску картки;
- після перевипуску картки токен оновлюється автоматично, повторні платежі не перериваються.

1.5. CVV/CVC

CVV2/CVC2 — тризначний код на картці, який емітент обчислює з PAN, строку дії та секретного ключа. В онлайн-платежі він підтверджує, що платник має доступ до самої картки, а не лише до її номера з якоїсь бази.

PCI DSS забороняє зберігати чутливі дані автентифікації, включно з CVV2, після авторизації, навіть у зашифрованому вигляді [1]. Цінність коду саме в тому, що його немає в базах продавців. Якщо його зберігати, витік бази дасть зловмиснику повний набір для платежів без присутності картки.

1.6. 3-D Secure

3-D Secure — протокол автентифікації держателя картки в онлайн-платежах [2]. Назва відбиває три домени: емітента (сервер автентифікації ACS), еквайра (3DS Server продавця або PSP) та взаємодії (Directory Server платіжної системи).

У версії 2.x продавець передає емітенту дані про пристрій і операцію. Емітент обирає frictionless-сценарій, коли ризик низький, або challenge — OTP, підтвердження в банківському застосунку, біометрію. Результатом є криптографічне значення автентифікації (CAVV/AAV), яке додається до запиту авторизації. Так автентифікація пов’язується з конкретною операцією, а відповідальність за шахрайську операцію переходить до емітента.

1.7. Вимоги постанови НБУ № 58

Постанова Правління НБУ від 03.05.2023 № 58 затвердила Положення про автентифікацію та застосування посиленої автентифікації на платіжному ринку; вона набрала чинності 10.05.2023 [4]. Положення реалізує Закон України «Про платіжні послуги» та гармонізує регулювання з правом ЄС [5]. Основні вимоги:

- посилена автентифікація застосовується під час дистанційного доступу до рахунку, ініціювання дистанційної платіжної операції та інших дій із ризиком шахрайства;

- використовуються щонайменше два незалежні елементи з різних категорій: знання (пароль, PIN), володіння (телефон, токен) та притаманність (біометрія); компрометація одного не повинна компрометувати інший;
- надавач формує унікальний код автентифікації, динамічно пов'язаний із сумою та отримувачем; зміна суми чи отримувача робить код недійсним;
- надавачі зобов'язані мати механізми виявлення шахрайських операцій з урахуванням факторів ризику.

Картка разом з одноразовим паролем у SMS уже не вважається достатньою, якщо код не пов'язаний з операцією [4].

1.8. Цифровий підпис і HMAC у взаємодії компонентів

TLS захищає з'єднання, але не саме повідомлення після його отримання. Підпис або HMAC додає захист рівня повідомлення:

- HMAC зі спільним ключем [10] автентифікує запити продавця до API провайдера та сповіщення (webhook) провайдера про статус платежу. Без нього зловмисник міг би надіслати продавцю фальшиве «оплачено»;
- цифровий підпис дозволяє будь-якій стороні з відкритим ключем перевірити автора та забезпечує неспростовність. Так підписуються повідомлення 3-D Secure і платіжні токени Apple Pay;
- у самій картковій мережі емітент перевіряє одноразову криптограму чипа або токена (MAC на ключі картки).

У поєднанні з міткою часу, nonce або ідентифікатором запиту ці механізми захищають також від повторного відтворення.

1.9. Стандарт PCI DSS

PCI DSS — стандарт безпеки даних індустрії платіжних карток, який розробляє PCI Security Standards Council; чинна версія — 4.0.1 [1]. Він обов'язковий для всіх, хто зберігає, обробляє або передає дані карток: продавців, провайдерів, процесингових центрів.

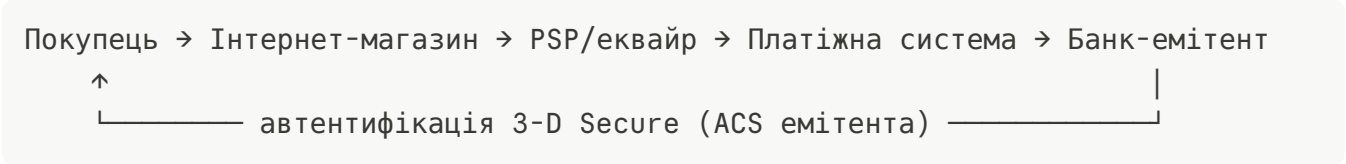
Стандарт захищає два класи даних. Перший — дані держателя: PAN, ім'я, строк дії, сервісний код; PAN дозволено зберігати лише в нечитабельному вигляді. Другий — чутливі дані автентифікації: повні дані смуги або чипа, CVV2, PIN і PIN-блок, які заборонено зберігати після авторизації.

Захищається середовище даних держателів карток (CDE) і пов'язані з ним системи. Дванадцять вимог охоплюють мережеві засоби захисту, безпечну конфігурацію, захист збережених даних, шифрування при передаванні, захист

від шкідливого ПЗ, безпечну розробку, контроль доступу та MFA, журналювання, тестування й політики безпеки.

2. Аналіз проведення електронного платежу

Розглянуто оплату замовлення карткою на сторінці платіжного провайдера з 3-D Secure. Повні реквізити картки бачать лише PSP і учасники карткової мережі; магазин отримує тільки результат і токен.



Таблиця 2 — Етапи проведення платежу

Етап	Дані	Хто має доступ	Захист
1. Оформлення замовлення	Склад замовлення, сума, ідентифікатор замовлення	Покупець, магазин	TLS; запит магазину до PSP із сумою підписується HMAC
2. Введення реквізитів	PAN, строк дії, CVV2	Покупець, PSP (магазин не бачить: сторінка або iframe провайдера)	TLS; PSP токенізує PAN, CVV2 не зберігається
3. Автентифікація 3-D Secure	Дані пристрою та операції, сума, продавець; відповідь на challenge	PSP (3DS Server), Directory Server, ACS емітента	TLS, підписані повідомлення 3DS; результат — значення CAVV/AAV
4. Авторизація	PAN або токен з криптограмою, сума, ID продавця, CAVV	Еквайр, платіжна система, емітент	Захищені канали мережі ПС, MAC повідомлень, перевірка криптограми емітентом
5. Повідомлення результату	Статус «схвалено/ відхилено», код авторизації	Емітент → еквайр → PSP → магазин → покупець	Підписаний webhook (HMAC) до магазину; TLS

Етап	Дані	Хто має доступ	Захист
6. Клірінг і розрахунки	Підсумки операцій за період	Еквайр, платіжна система, емітент	Внутрішні захищені канали ПС

Захисту від розголошення потребують PAN, CVV2 та облікові дані автентифікації; від модифікації — сума, отримувач, ідентифікатор замовлення та статус оплати.

Автентифікація відбувається на етапі 3 і виконується емітентом через ACS: у frictionless-сценарії за ризик-даними, у challenge-сценарії — підтвердженням у банківському застосунку або одноразовим кодом, пов'язаним із сумою та отримувачем. Магазин і PSP не перевіряють облікові дані користувача, а лише передають результат.

Підтвердження або відхилення виконує емітент на етапі 4. Він перевіряє CAVV або криптограму, статус картки, залишок і ліміти, оцінку шахрайства й повертає код відповіді. Відповідь іде зворотним ланцюжком; магазин відвантажує товар лише після перевірки підпису сповіщення від PSP.

Чому TLS недостатньо

TLS захищає лише кожен окремий мережевий сегмент і лише під час передавання. Він не визначає, хто є законним держателем картки, не обмежує використання викрадених реквізитів і не захищає збережені дані. TLS також не захищає від повторного надсилання запиту автентифікованим клієнтом, від шкідливого коду на сторінці оплати чи від підробки статусу всередині системи. Ці задачі вирішують 3-D Secure і посилена автентифікація, токенізація, вимоги PCI DSS до зберігання, підпис повідомлень та контроль унікальності операцій.

3. Аналіз ситуацій порушення безпеки

Ситуація 1. Перехоплення мережевого трафіку

За коректного HTTPS/TLS пасивний спостерігач отримує лише метадані: IP-адреси, доменне ім'я з SNI (якщо не використовується ECH), час, обсяги та розміри пакетів. З них можна зробити висновок про факт відвідування магазину чи платіжної сторінки, але не про реквізити, суму чи вміст замовлення.

TLS захищає від читання реквізитів і облікових даних, від непомітної зміни суми або отримувача та від підміни сервера за умови перевірки сертифіката [9]. Не захищає від аналізу трафіку за метаданими й від загроз на самих кінцевих

точках.

Ситуація 2. Компрометація бази даних продавця

Якщо магазин зберігав платіжні реквізити, зловмисник отримує PAN, строки дії та імена. Їх можна продати або використати для платежів у продавців без 3-D Secure, а банкам доведеться масово перевипускати картки. Якщо в базі був і CVV2, це пряме порушення PCI DSS, а наслідки найгірші [1].

Якщо магазин зберігав лише токени, вони марні поза доменом магазину: мережевий токен потребує криптограми, а токен PSP працює лише через API провайдера з ключами магазину. Наслідки зводяться до витоку персональних даних, а скомпрометовані токени відкликаються без перевипуску карток.

Токенізація переносить цінні дані з багатьох систем продавців до кількох добре захищених сховищ провайдерів і платіжних систем. Площа атаки та обсяг вимог PCI DSS для продавця зменшуються.

Ситуація 3. Повторне проведення операції

Це атака повторного відтворення (replay). Їй запобігають такі механізми:

- унікальний ідентифікатор замовлення або ключ ідемпотентності: PSP не проводить вдруге запит із тим самим ідентифікатором;
- мітка часу та nonce, захищені HMAC або підписом: старий або вже використаний запит відхиляється;
- одноразові значення в картковій мережі: криптограма токена чи чипа обчислюється з лічильника операцій і приймається лише раз, CAVV 3-D Secure пов’язаний з однією операцією;
- код посиленої автентифікації за постановою НБУ № 58 одноразовий і пов’язаний із сумою та отримувачем [4].

Ситуація 4. Модифікація параметрів платежу

На мережевому шляху зміну суми або отримувача виявляють теги цілісності TLS. На рівні застосунку запит магазину до PSP із сумою, валютою й ідентифікатором продавця захищається HMAC або підписом; PSP відхиляє запит із невідповідним тегом. Сповіщення про результат також підписуються, щоб не можна було підробити статус.

Прикладні механізми доповнюють криптографію. Сума обчислюється на сервері з власних даних замовлення, а не приймається від браузера. Під час 3-D Secure емітент показує користувачу суму та отримувача, а код автентифікації

динамічно пов’язаний саме з ними [4]. Емітент перевіряє, що сума в авторизації відповідає автентифікованій.

Ситуація 5. Компрометація облікових даних користувача

Логіна й пароля недостатньо: потрібен ще елемент іншої категорії — володіння (телефон із банківським застосунком) або притаманність (біометрія). 3-D Secure переносить автентифікацію до емітента, і зловмисник без пристрою користувача не завершить challenge. Код, пов’язаний із сумою й отримувачем, не можна перенести на іншу операцію.

Ризики залишаються:

- соціальна інженерія — жертву вмовляють самостійно підтвердити операцію або продиктувати код;
- перехоплення SMS-кодів через SIM-swap або шкідливе ПЗ на телефоні;
- фішингові сторінки, що в реальному часі передають введені коди (real-time phishing);
- frictionless-сценарій 3-D Secure, коли емітент оцінив ризик як низький і додатково не запитав підтвердження;
- операції без 3-D Secure, наприклад у продавців, які його не підтримують.

4. Дослідження сучасного способу платежів: Apple Pay

Apple Pay замінює номер картки токеном пристрою (Device Account Number, DAN) і для кожної операції створює одноразову криптограму. Ключ для її обчислення зберігається в Secure Element, а платіж дозволяється лише після автентифікації користувача в Secure Enclave [6]. Схему платежу наведено на рис. 1.



Рисунок 1 — Схема платежу Apple Pay

4.1. Учасники

- користувач і його пристрій Apple: Secure Enclave (біометрія, код-пароль) та Secure Element (платіжний аплет з DAN і ключем);
- продавець: NFC-термінал у магазині або застосунок/вебсайт з Apple Pay;
- сервери Apple Pay: беруть участь у додаванні картки та в онлайн-платежах; у безконтактних платежах участі не беруть;
- PSP та еквайр продавця;
- платіжна система як постачальник токенів (TSP): випускає DAN і зіставляє його з реальним PAN;
- банк-емітент: перевіряє картку при додаванні, перевіряє криптограму й авторизує операцію.

4.2. Дані та credentials

- **DAN** — мережевий токен, унікальний для пристрою; PAN на пристрої не зберігається, а Apple не має доступу до DAN [6];
- **ключ платіжного аплета** — записується в Secure Element при персоналізації; відомий лише платіжній системі та/або емітенту;
- **лічильник операцій** — збільшується з кожною операцією й входить до криптограми;
- **платіжна криптограма** — одноразовий код з ключа, лічильника та даних операції: непередбачуваного числа термінала (NFC) або anti-replay значення сервера Apple Pay (онлайн) [6];
- **ключі сполучення Secure Enclave і Secure Element** та значення Authorization Random, яке прив’язує дозволи до додавання картки;
- **ключ сертифіката обробки платежів продавця** — для онлайн-платежів, ним шифрується платіжний токен.

4.3. Де зберігається найкритичніша інформація

Ключ платіжного аплета та DAN зберігаються в Secure Element — окремому захищеному чипі, недоступному для iOS і застосунків. Біометричні шаблони та ключі автентифікації — у Secure Enclave і не залишають його. Відповідність DAN → PAN зберігається лише у сховищі токенів платіжної системи, а ключі перевірки криптограм — у платіжної системи та/або емітента.

4.4. Автентифікація користувача

Користувач підтверджує намір платити жестом (подвійне натискання бічної кнопки або підтвердження в інтерфейсі) і автентифікується в Secure Enclave: Face ID, Touch ID або код-пароль. Secure Enclave надсилає Secure Element підписаний дозвіл з типом автентифікації та типом операції; лише після цього аплет видає криптограму [6].

Пристрій виконує роль елемента володіння, біометрія чи код-пароль — притаманності або знання. Тому автентифікація на пристрої (CDCVM) відповідає двофакторній моделі посиленої автентифікації. Результат перевірки (CVM) передається емітенту в даних операції.

При додаванні картки емітент окремо ідентифікує користувача, наприклад кодом у банківському застосунку або SMS. Це критичний етап: саме він визначає, чи додасть зловмисник викрадену картку.

4.5. Підтвердження операції

1. Пристрій передає DAN, криптограму та результат CVM: через NFC терміналу або, для онлайн-оплати, у зашифрованому платіжному токені.
2. Онлайн-токен шифрується відкритим ключем сертифіката обробки платежів продавця і підписується Apple; розшифровує його PSP або продавець [7].
3. Еквайр надсилає авторизацію в платіжну систему; TSP перевіряє криптограму, зіставляє DAN з PAN і передає запит емітенту.
4. Емітент перевіряє криптограму та лічильник, CVM, залишок і ризики, після чого схвалює або відхиляє операцію.

4.6. Криптографічні механізми

Механізм	Що забезпечує
Токенізація (DAN)	PAN не потрапляє до продавця, Apple чи пристрою; витік DAN без ключа аплета марний
Одноразова криптограма (MAC на ключі аплета з лічильником і непередбачуваним числом)	Автентичність пристрою та захист від повторного відтворення
Апаратна ізоляція: Secure Element і Secure Enclave	Ключі й біометрію неможливо витягти програмно

Механізм	Що забезпечує
ECDH між Secure Enclave і Secure Element; підписаний дозвіл	Аплет працює лише після реальної автентифікації користувача
Шифрування токена на ключ продавця (ECDH + AES-GCM) та підпис Apple	Конфіденційність і цілісність даних онлайн-платежу між пристроєм і PSP
TLS	Захист каналів між пристроєм, серверами Apple, продавцем і PSP

4.7. Характерні загрози

- **Шахрайське додавання картки:** зловмисник з викраденими реквізитами виманює в жертви код підтвердження емітента та додає картку на свій пристрій. Криптографія пристрою тут не допомагає — усе залежить від ідентифікації при додаванні.
- **Викрадення пристрою з відомим код-паролем:** код є резервним способом автентифікації. Протидія — функція «Знайти» для блокування карток і віддалене видалення.
- **Relay-атаки на безконтактні платежі,** зокрема в режимі Express Transit без автентифікації: пристрій ретранслює обмін до віддаленого термінала.
- **Компрометація ключа обробки платежів продавця або PSP:** розкриває розшифровані онлайн-токени цього продавця, але без можливості повторного використання криптограм.
- **Соціальна інженерія:** користувача змушують самого підтвердити платіж зловмиснику.

5. Історичний протокол: PayWord

PayWord запропонували Р. Рівест та А. Шамір у 1996 році для мікроплатежів [8]. Ідея протоколу — замінити операцію з відкритим ключем на кожен платіж одним підписом на серію платежів та дешевими обчисленнями хеш-функції.

5.1. Задача

Мікроплатежі — це плата в частки цента за сторінку, запит або хвилину сервісу. Для них звичайна схема неприйнятна: цифровий підпис і онлайн-звернення до банку на кожну операцію коштують більше за саму операцію. Потрібна була схема, де продавець перевіряє платіж локально й швидко, а з брокером взаємодіє рідко і пакетно.

5.2. Принцип роботи

Учасники: користувач, продавець і брокер (посередник, що веде рахунки обох).

1. **Сертифікат.** Брокер підписує сертифікат користувача: ідентичність, відкритий ключ, строк дії, кредитні умови. Сертифікат свідчить продавцям, що брокер оплатить коректні платежі цього користувача.
2. **Ланцюжок.** Користувач обирає випадкове значення w_n і обчислює ланцюжок хешів у зворотному напрямку до w_0 (корінь).
3. **Зобов'язання.** Перед покупками в продавця користувач підписує зобов'язання: ім'я продавця, сертифікат, корінь w_0, дату. Це єдина операція з відкритим ключем для всієї серії платежів цьому продавцю.
4. **Платежі.** Кожен i-й платіж — це наступне значення ланцюжка w_i. Продавець перевіряє лише рівність h(w_i) = w_{i−1}; платіж на k одиниць — значення w_{i+k}.
5. **Розрахунок.** У кінці дня продавець передає брокеру зобов'язання та останнє отримане значення w_l. Брокер перевіряє підпис і l хешувань, зараховує продавцю l одиниць і списує їх з рахунку користувача.

```
w_{i-1} = h(w_i),\quad i = n, \ldots, 1;\qquad \text{платіж } i:\ h(w_i) \overset{?}{=} w_{i-1}
```

```
w_n → h → w_{n-1} → h → … → w_1 → h → w_0 (підписаний корінь)
порядок витрачання:  w_1, w_2, …, w_l
```

5.3. Криптографічні механізми

Механізм	Призначення
Підпис брокера на сертифікаті користувача	Автентичність користувача та гарантія оплати брокером
Підпис користувача на зобов'язанні	Прив'язка ланцюжка до користувача й конкретного продавця, неспростовність
Одностороння хеш-функція (ланцюжок PayWord)	Дешева перевірка кожного платежу; неможливість обчислити наступні значення з уже отриманих

5.4. Властивості безпеки

- **Неможливість підробки:** продавець не може «дописати» платежі, бо обчислити w_{i+1} з w_i заважає одностороння властивість h.
- **Неспростовність:** підписане зобов'язання та отримані значення ланцюжка доводять брокеру, що користувач витратив l одиниць.
- **Прив'язка до продавця:** ланцюжок не можна витратити в іншого продавця, бо зобов'язання називає конкретного продавця.
- **Захист від повторного витрачання:** продавець приймає кожен індекс лише раз; повторна подача брокеру того самого ланцюжка не збільшує суму.
- **Обмежений ризик:** користувач може перевищити кредит у кількох продавців одночасно. PayWord свідомо обирає виявлення зловживань і обмеження кредиту замість їх криптографічного запобігання, бо суми малі.

Анонімності користувача схема не дає: брокер бачить, у яких продавців і скільки він витрачав.

5.5. Порівняння із сучасними платежами

Аспект	PayWord	Сучасні платежі
Довіра до користувача	Сертифікат брокера	Картка або токен, випущені емітентом; токен пристрою в Apple Pay
Автентифікація	Один підпис на серію платежів продавцю	Посилена автентифікація на кожну дистанційну операцію, з винятками для низького ризику
Перевірка платежу	Офлайн, продавцем, хешуванням	Онлайн-авторизація емітентом за одноразовою криптограмою (симетричний MAC)
Захист від повтору	Індекс у хеш-ланцюжку	Лічильник операцій у криптограмі, ідентифікатори операцій
Розрахунки	Пакетно, раз на день	Онлайн-авторизація, пакетні клірінг і розрахунки

Сучасні карткові системи пішли іншим шляхом: обчислювальна вартість криптографії вже не є проблемою, тому кожну операцію авторизує емітент онлайн. Проте ідеї PayWord збереглися в інших місцях. Пакетні розрахунки лежать в основі клірінгу. Хеш-ланцюжки застосовуються в одноразових паролях. Найближчий сучасний аналог — платіжні канали криптовалют, де серію дрібних платежів проводять поза основною мережею і фіксують одним підсумковим записом.

Висновки

Захист електронного платежу будується шарами, і кожен шар закриває свій клас загроз. TLS захищає дані під час передавання, але не визначає законного держателя і не захищає збережені дані. Автентифікацію виконує емітент через 3-D Secure; за постановою НБУ № 58 вона має бути двофакторною й динамічно пов’язаною із сумою та отримувачем. Авторизацію як окреме рішення щодо операції ухвалює також емітент.

Токенізація та заборона зберігати CVV2 за PCI DSS зменшують наслідки витоку баз продавців. Підпис і HMAC разом з ідентифікаторами операцій та одноразовими криптограмами протидіють модифікації та повторному відтворенню запитів. Apple Pay поєднує ці механізми на пристрої: токен DAN, одноразова криптограма та апаратна автентифікація в Secure Enclave; найслабшим місцем залишається додавання картки та соціальна інженерія. PayWord показує альтернативний підхід — офлайн-перевірку дешевими хеш-ланцюжками з одним підписом на серію платежів; ця ідея збереглася в пакетних розрахунках і платіжних каналах.

Використані джерела

1. PCI Security Standards Council — PCI DSS v4.0.1
2. EMVCo — EMV 3-D Secure Protocol and Core Functions Specification
3. EMVCo — EMV Payment Tokenisation Specification: Technical Framework
4. Постанова Правління НБУ від 03.05.2023 № 58 «Про затвердження Положення про автентифікацію та застосування посиленої автентифікації на платіжному ринку»
5. Закон України «Про платіжні послуги» від 30.06.2021 № 1591-IX
6. Apple Platform Security — Payment authorization with Apple Pay
7. Apple Developer — Payment token format reference
8. R. L. Rivest, A. Shamir — PayWord and MicroMint: Two simple micropayment schemes, 1996

9. RFC 9846 — The Transport Layer Security Protocol Version 1.3
10. RFC 2104 — HMAC: Keyed-Hashing for Message Authentication